SOP - SECURE DESIGN

[CONFIDENTIAL]
[UTTHUNGA]
[IndiQube, South Summit, South End Rd, Vijayarangam Layout, Bengaluru, Karnataka 560004]

Contents

1 Purpose 3
2 Scope 3
3 Abbreviations 3
4 Terms and Definitions 3
5 Responsibilities 3
6 RACI 4
7 SIPOC 4
8 Overall Process Flow Chart 7
9 Process Description 8
10 Information Security requirements 12
11 References 12
12 Metrics 13
13 Annexures 13
14 Forms 13

CHANGE HISTORY

This section describes the details of changes that have resulted in the current document.

SL. No.	Document Version No.	Change Description	Reason For change	Date Prepared By	Date Reviewed By	Date Approved By
01	0.1	Draft – New process as per IEC 62443-4-1		Anitha N 04-04-24		
02	Issue B, V1.0	New Process			Santosh V 10-05-24	Santosh V 10-05-24
03	Issue B V1.1	1. Updated Section 14 2. Document formatting done as per document guidelines	Provided relevant links for forms related to SOP	Vanavee P 09-Dec-24	Anitha N 09-12-24	Santosh V 10-12-24
04	Issue C Version 1.0	Review of document	New version update of IMS	Anitha N 01-Aug-25	Santosh V 08-Aug-25	Sanmangala 14-Aug-25

1 Purpose

This process satisfies the following IEC 62443-4-1 requirements for "Secure by Design" (SD- 1 to SD-4)

2 Scope

Utthunga shall adopt security by design principles to ensure that the product's design sufficiently.
addresses the associated cybersecurity risks.

3 Abbreviations

a. IACS: Industrial Automation and Control System

b. RACI: Responsible, Accountable, Consulted, and Informed

c. SD: Security Design

d. IMS: Information Management System

e. JTAG: Joint Test Action Group

f. SWD: Serial Wire Debug

4 Terms and Definitions

a. IEC 62443-4-1: Industrial communication networks – Network and system security – Part 4-1: Secure product development lifecycle requirements

b. Threat Modeling: Performing a structured analysis to identify potential threats and vulnerabilities to the IACS environment.

c. Defense in Depth: Implementing multiple layers of security measures to protect an asset.

d. Trust Boundary: Where authentication and authorization requirements change.

e. Attack Surface: All points where an unauthorized user or system can try to enter or extract data.

5 Responsibilities

a. Development teams are responsible for the security of applications they create and maintain.

b. Each team, in consultation with Cybersecurity, keeps a threat model of its application, operating environment, and data flow boundaries.

c. Project teams shall implement defense in depth security practice.

d. Project teams shall consider secure design best practices to improve security.

e. Security design should be included in the design review process and conducted at least once a year or whenever the design changes.

6 RACI

Process	Responsible	Accountable	Consulted	Informed
Design	Development Teams, Cybersecurity	Team Lead	Stakeholders, Architects	Customer & Engineering Teams, Product Security Teams
Secure the interfaces of the product	Development Teams	Team Lead	Cybersecurity	Product Security Teams
Adopting defense in depth	Project Teams	Team Lead	Cybersecurity	Stakeholders
Following secure design best practices	Project Teams	Team Lead	Cybersecurity	Stakeholders
Reviewing security design	Cybersecurity, Development Teams	Team Lead	Stakeholders, Product Security Teams	Customer & Engineering Teams

7 SIPOC

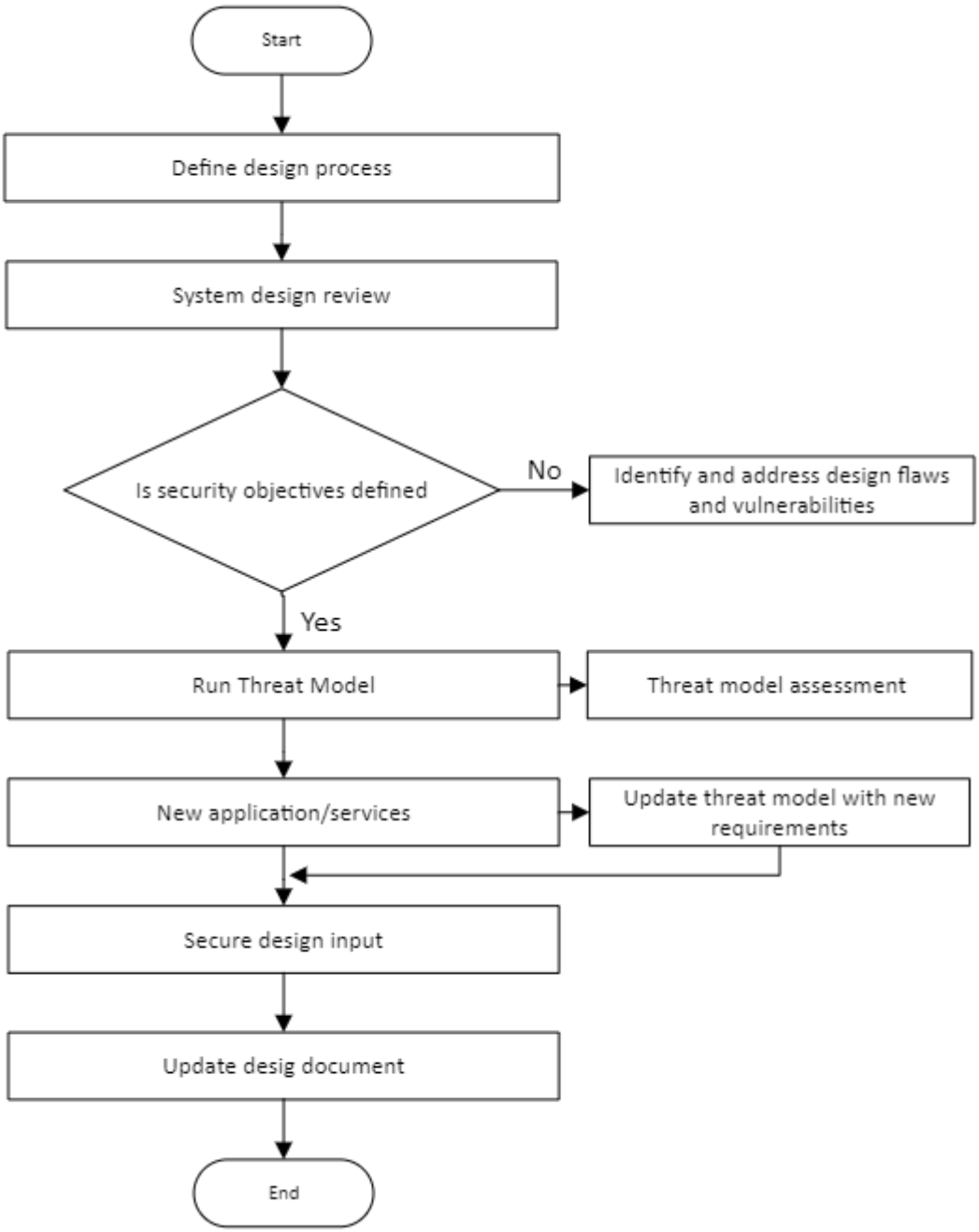
Supplier	Input	Process and Control		Output	Customer
		Process	Control		
Development Teams, Cybersecurity	Initial design framework, security principles, requirements, stakeholders	Design	Implement multiple layers of security measures, least privilege access, Use of secure design patterns, Minimize the attack surface, Proper error handling, sanitize all external input, Separate responsibilities/duties, avoid security	Design document, threat model	Stakeholders, Customer & Engineering Teams, Product Security Teams

			by obscurity, Avoid hardcoded secrets		
Development Teams	List of all interfaces, security context, use cases, user roles, assets accessible, trust boundary, security assumptions, other considerations, security threats, security mechanisms	Secure the Interfaces	Implementation of secure design principles, Authorization, Input sanitization, Error handling, Anomaly detection	Secure interfaces documentation, security threats analysis	Cybersecurity, Product Security Teams
Project Teams	Security best practices, project requirements	Adopting Defense in Depth	Implementation of multiple layers of security measures, avoid relying on a single security mechanism, avoid user-friendliness reduction, Avoid system availability/stability reduction	Implemented defense in depth measures	Stakeholders, Customer & Engineering Teams, Product Security Teams
Project Teams	Secure design principles, security patterns	Secure Design Best Practices	Least privilege access, use existing secure components, use secure design patterns, Minimize the attack surface, Fail securely, Sanitize all external input, Separate	Implemented secure design best practices	Cybersecurity, Product Security Teams

			responsibilities/duties, Remove unnecessary interfaces, Avoid security by obscurity, Avoid hardcoded secrets		
Cybersecurity, Development Teams	Security design, product interfaces, security best practices	Reviewing Security Design	Review of security design, documented evidence, security review items, captured security analysis	Review report	Stakeholders, Customer & Engineering Teams, Product Security Teams

8 Overall Process Flow Chart

a) Secure design



9 Process Description

9.1 General Procedure

a. Design process involves establishing the initial design framework and requirements for the industrial automation and control system (IACS) based on security principles and best practices.

b. Design document shall include defining the scope of the design, gathering initial requirements, identifying stakeholders, and establishing the foundational elements of the system architecture. Note: Refer Utthunga' s secure design principles. Secure design principles will help the developers to build secure application/product.

c. Comprehensive review of the system design shall be done to ensure it aligns with security objectives, industry standards, and regulatory requirements. This shall include reviewing architectural diagrams, component specifications, security controls, trust boundaries, entry points, data flows, privileges code and threat mitigation strategies.

d. Team shall identify and address any design flaws, vulnerabilities, or compliance issues before proceeding to the implementation phase.

e. Team shall establish a Threat Modeling which involves performing a structured analysis to identify potential threats and vulnerabilities to the IACS environment.

f. This may include identifying assets, conducting threat assessments, analyzing attack vectors, and prioritizing risks based on likelihood and impact. The goal is to inform the design and implementation of security controls by proactively addressing potential threats and mitigating security risks.

g. When a new application or service is used, threat model shall be created during the design phase.

h. When a new feature on an existing application or service is developed, update the existing threat model to incorporate/eliminate attack surfaces based on the new feature.

i. Development teams are responsible for the security of applications they create and maintain. Each team, in consultation with Security expert, keeps a threat model of its application, operating environment, and data flow boundaries.

j. The Threat Model should be reviewed and updated by the customer, Security Architect and their product security teams at least once prior to each release. Refer detailed Threat model guidelines is available in IMS.

k. Secure Design Input will be provided by giving guidance to the design team regarding security requirements, controls, and best practices. This shall include collaborating with architects, developers, and stakeholders to incorporate security considerations into the design process.

l. Security User Story shall be updated by adding user stories or requirements documentation which includes security-related features, functionalities, and constraints. This may include revising user stories to incorporate security requirements, prioritizing security-related tasks, and tracking progress through agile development cycles.

m. Design document shall be reviewed and updated by relevant stakeholders.

9.2 Secure the Interfaces of the Product

a. As per SD-1 of IEC 62443-4-1, The interfaces exposed by the product are often the major entry points for attackers. Therefore, it is important to track the interfaces exposed by the product and what measures to be taken to prevent the attacker from abusing these interfaces.

b. When designing product features, include a list of all interfaces of the product with the following information.

- Whether the interface is external (accessible by other products) or internal (accessible only by other components in the same product)
- The implications from the product security context of components connected to the product's external interfaces. This includes the presence or lack of security features of the externally connected components, which would justify the focus of the security design.

A description of the use cases of the external interfaces

- The user roles that could access the interfaces, including their privileges or access control permissions.
- The assets that are accessible through the interfaces such as user data, sensor measurements, and system configuration
- Whether the access to interfaces crosses a trust boundary, which is where authentication and authorization requirements change.
- Security assumptions of external entities that can access the external interface.

- Other considerations, assumptions, and constraints when using the interfaces.
- The security threats on the interfaces
- The security mechanisms used to safeguard the interfaces and the assets, which include techniques like authorization, input sanitization, error handling, and anomaly detection. This includes any third-party products used to implement the interfaces and their security capabilities.
- Description or security analysis of how such a design mitigates the threats identified during the process of Specifying Security Requirements.

9.3 Adopting Defense in Depth

a. As per SD-2 of IEC 62443-4-1, Project teams shall implement defense in depth security practice instead of relying on one single security mechanism as a single point of failure.

b. Defense in depth applied to multiple layers of security measures to protect an asset. This ensures that the attacker must overcome multiple security measures, with each reducing the overall attack surface before they can successfully compromise a component or system.

c. When designing defense in depth, apply the following principles and methodology:
   - Aim to have a consistent level of defense in depth across similar components.
   - Avoid having a component design that relies solely on the security of another component.
   - Avoid designing security measures that significantly reduce user-friendliness.
   - Avoid designing security measures that significantly reduce system availability or stability.
   - Adapt the principles above to suit your project.

9.4 Following Secure Design Best Practices

a. As per SD-4 of IEC 62443-4-1 requirements, during product design, project teams shall consider the following best practices to improve security.
   - Least privilege: Users and components are only given minimal permissions to perform their tasks. E.g., executing programs as regular users instead of root, rejecting write activities from software components that should only read data.

- Use existing and proven secure components: Avoid implementing custom security mechanisms unless they are not offered by existing open-source libraries or software stacks. Refrain from implementing custom cryptographic algorithms like encryption or hashes. Keep security mechanisms simple.
- Use secure design patterns: Review design against common security patterns and anti- patterns (see reference below)
- Minimize the attack surface (with documented evidence such as requirements. Redmine/Jira tasks, and test cases): Avoid exposing the product through unused services and block the execution of unnecessary software.
- Fail securely: Expect the product to fail and handle errors properly and gracefully. E.g., handle all software exceptions to avoid program termination.
- Sanitize all external input: Always validate external input before processing it.
- Separate responsibilities/duties: Separate duties between different components and user types
- Remove unnecessary interfaces and debug interfaces: Close or disable interfaces that are not used in product features, such as JTAG. SWD, unused USB ports, etc.
- Avoid security by obscurity: Design products that are still secure even if detailed product designs are leaked. In other words, base your product's security on secret keys instead of secret designs.
- Avoid hardcoded secrets: Do not hardcode passwords or other credentials in code: always allow (encourage or enforce) password changes or automated password generation during product commissioning.

9.5 Reviewing Security Design

a. As per SD-3 of IEC 62443-4-1 requirements, to ensure that the security design addresses the threat model and follows best practices (as described above, also available in Secure Design principles guidelines), include the security design in the design review process and conduct the review at least once a year or whenever the design changes. Pay additional focus on the following actions:

- Review security design for parts of the product that are subject to security threats during Specifying Security Requirements

- Ensure that documented evidence of the review, such as tasks, meeting notes, and referenced design revision tracked.
- Include the following items in the security review:
  - The Threat Model in Specifying Security Requirements, Performing Continuous Threat Modeling, particularly the security requirements not addressed by the security design under review.
  - The documented information about the product's interfaces (as described above)
  - The security design best practices (as listed above)
- Create a review report containing at least the following:
  - The date
  - The reviewed product and version
  - The people involved in the review.
  - The identified design issues to resolve, where the issues can be tracked in tools.
- During the reviews, the participants can also propose to improve the process as needed by following the actions mentioned in Security Management and Establish Continuous Improvement process.
- Description or security analysis of how such a design mitigates the threats identified during the process of Specifying Security Requirements needs to be captured.
- Consider using the Template: Security Analysis for Product Interfaces template to fill in the necessary information for each interface.

10 Information Security requirements

a. Implementing multiple layers of security measures (Defense in Depth).
b. Least privilege access.
c. Use of secure design patterns.
d. Minimize the attack surface.
e. Proper handling of errors and exceptions.
f. Sanitize all external input.
g. Separate responsibilities/duties.
h. Avoid security by obscurity.
i. Avoid hardcoded secrets.

11 References

a. SOP-Design (DSP)-UTSDDSPSOP.pdf
b. 04. SDL_Third Party Components Management Guidelines UTSDDSPGDL04.pdf

c. 2. Threat Modeling Guidelines UTSDDSPGDL02.pdf
d. 3. Vulnerability Handling Guidelines UTSDDSPGDL03.pdf
e. 4. Security Guidelines UTIECGDL04.pdf

12 Metrics

a. Number of design flaws or vulnerabilities identified and addressed.
b. Number of threat modeling sessions conducted.
c. Number of security design reviews conducted per year.
d. Number of design issues resolved.
e. Number of security best practices implemented.

13 Annexures

a. Detailed Threat model guidelines
b. Template: Security Analysis for Product Interfaces

14 Forms

a. 3. Secure Design Interface Checklist UTIECTMP03.xlsx
b. 1. Design Document Template UTSDDSPTMP01.docx
c. 3. Security Architecture and Design Review Checklist UTSDDSPTMP03.xlsx